

第 15 章

身份认证技术

15.1

身份证明

在充满竞争的现实社会中,身份欺诈时有发生。为了防止身份欺诈,常常需要个人身份认证。通信和数据系统的安全性也取决于能否正确验证用户或终端的个人身份。例如,银行的自动柜员机(Automatic Teller Machine, ATM)可将现金发给经它正确识别的账号持卡人,从而提高银行的工作效率和服务质量。计算机的访问和使用、安全区的出入,也都以精确的身份认证为基础。

传统的身份证明一般是通过检验“物”的有效性来确认该物持有者的身份。“物”可以为徽章、工作证、信用卡、驾驶证、身份证、护照等,卡上含有个人照片(易于换成指纹、视网膜图样、牙齿的X光照相等),并有权威机构签章。过去这类靠人工进行的识别工作现在已逐步由机器代替。在信息化社会中,随着信息业务的扩大,要求验证的对象集合也迅速加大,因而大大增加了身份验证的复杂性和实现的困难性。例如,银行自动转账系统中可能有上百万个用户,若用个人识别号(Personal Identification Number, PIN),至少需要6位十进制数字。若要用户个人签字来代替PIN,必须能区分数以百万计的人的签字。

目前,一些采用电子方式实现个人身份证明的方法均存在安全风险。例如,从银行的ATM机取款时需要将信用卡和PIN送入其中;电话购货需证实信用卡的号码;用电话公司发行的电话卡支付长途电话费需验证4位十进制的PIN;网站登录时需输入用户的名字和口令等。但是,现实社会中的攻击者常常使这类简单的身份验证方法失效。

如何实现安全、准确、高效和低成本数字化认证,是目前网络安全实践中的一个热点。本章将讨论几种常用的身份认证技术,如口令认证系统、基于个人生物特征的身份证明及一次性口令身份认证系统等。

15.1.1 身份欺诈

下面给出一些例子,说明几种可能的身份欺诈的方式。

1. 象棋大师问题(The Chess Grandmaster Problem)

A不懂象棋,但可向Kasparov和Karpov同时挑战,在同一时间和地点(不在一个房间)进行对弈,以白子棋对前者、以黑子棋对后者,而两位大师彼此不交流,如图15-1所示。Karpov持白子棋先下一步,A记下该步并下同样一招棋对付Kasparov,而后看

Kasparov 如何下黑子棋，A 记下这第二步并下同样一招棋对付 Karpov，依此类推。在这场博弈中，A 是中间人，他实施的就是一种中间人欺诈攻击。

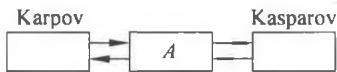


图 15-1 象棋大师问题

2. Mafia 欺诈

A 在 Mafia 集团成员 B 开的饭馆吃饭，Mafia 集团另一成员 C 到 D 的珠宝店购买珠宝，B 和 C 之间有秘密无线通信联络，A 和 D 不知道其中有诈。A 向 B 证明 A 的身份并付账，B 通知 C 开始欺骗：A 向 B 证明身份，B 经无线通知 C，C 以同样协议向 D 证明身份。当 D 询问 C 时，C 经 B 向 A 问同一问题，B 再将 A 的回答告诉 C，C 向 D 回答，如图 15-2 所示。实际上，B 和 C 起到中间人作用而完成 A 向 D 的身份证明，达到了 C 向 D 购买了珠宝，而把账记在 A 的账上的目的。这是中间人 B 和 C 合伙进行的欺诈。

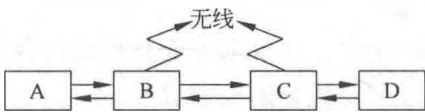


图 15-2 中间人合伙欺诈

3. 恐怖分子欺诈

假定 C 是一名恐怖分子，A 要帮助 C 进入某国，D 是该国移民局官员，A 和 C 之间用秘密无线电联络，如图 15-3 所示。A 协助 C 得到 D 的入境签证。

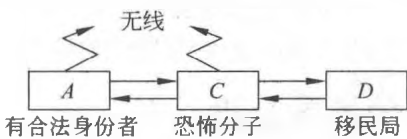


图 15-3 另一种中间人合伙欺诈

这类欺诈攻击可以用防电磁辐射和精确时戳等技术来抗击。

4. 多身份欺诈 (Multiple Identity Fraud)

A 首先建立几个身份并向外公布。其中之一他从未用过，他以这一身份作案，并只用一次，除目击者 (Witness) 外无人知道犯罪人的个人身份。由于 A 不再使用此身份，警方无法跟踪。采用一种身份证颁发机构确保每人只有一个身份证，就可抗击这类欺诈。

15.1.2 身份证明系统的组成和要求

身份证明系统一般由三方组成：一方是出示证件的人，称做示证者 (Prover)，又称做申请者 (Claimant)，他提出某种入门或入网请求；另一方为验证者 (Verifier)，检验示证者出示证件的正确性和合法性，决定是否满足其要求；第三方是攻击者，他可以窃听并伪装示证者骗取验证者的信任。认证系统在必要时也会有第四方，即可信者，他的作用是参与调解纠纷。称此类技术为身份证明技术，又称做身份识别 (Identification)、实体认证 (Entity Authentication)、身份验证 (Identity Verification) 等。实体认证与消息

认证的差别在于：消息认证本身不具有时间性，而实体认证一般都具有实时性。此外，实体认证通常证实实体本身，而消息认证除了证实消息的合法性和完整性外，还要知道消息的含义。

对身份证明系统的要求如下：

- (1) 验证者正确识别合法示证者的概率极大化。
- (2) 不具有可传递性 (Transferability)，验证者 B 不可能重用示证者 A 提供给他的信息来伪装示证者 A 去骗取其他人的验证而获取信任。
- (3) 攻击者伪装示证者欺骗验证者成功的概率要小到可以忽略的程度，特别是要能抗击已知密文攻击，即能防止攻击者在截获示证者和验证者多次通信后伪装示证者以欺骗验证者。
- (4) 计算有效性（为实现身份证明所需的计算量要小）。
- (5) 通信有效性（为实现身份证明所需通信次数和数据量要小）。
- (6) 秘密参数能安全存储。
- (7) 交互识别（在有些应用中，要求双方能互相进行身份认证）。
- (8) 第三方的实时参与，如在线公钥检索服务。
- (9) 第三方的可信性。
- (10) 可证明安全性。

其中，(7)～(10)是对某些身份证明系统所提出的要求。

身份识别与数字签名密切相关。数字签名是实现身份识别的一个途径，但在身份识别中消息的语义基本上是固定的，身份验证者根据规定对当前时刻申请者提出的申请或接受或拒绝。身份识别一般不是“终生”的，而数字签名则应长期有效，在未来仍可启用。

15.1.3 身份证明的基本分类

身份证明可分为以下两大类。

(1) **身份验证**。它要回答这样一个问题——“你是否是你所声称的你？”即只对个人身份进行肯定或否定。一般方法是：在个人信息输入后，系统将经公式和算法运算所得的结果与从卡上（或库中）存储的信息经公式和算法运算所得结果进行比较，根据比较结果得出结论。

(2) **身份识别**。它要回答这样一个问题——“我是否知道你是谁？”一般方法是：在个人信息输入后，系统将其加以处理后提取出模板信息，并试着在存储数据库中搜索出一个与之匹配的模板，而后给出结论。例如，确定一个犯罪嫌疑人是否曾有前科的指纹检验系统就是一个身份识别系统。

显然，身份识别要比身份验证难得多。读者可以通过一些实例仔细体会身份验证系统和身份识别系统之间存在的差异。

15.1.4 实现身份证明的基本途径

身份证明可以依靠下述 3 种基本途径之一或组合实现，如图 15-4 所示。

(1) **所知 (Knowledge)**：个人所知道的或所掌握的知识，如密码、口令等。

(2) 所有 (Possesses): 个人所具有的东西, 如身份证、护照、信用卡、钥匙等。

(3) 个人特征 (Characteristics): 如指纹、笔迹、声纹、手型、脸型、血型、视网膜、虹膜、DNA 及个人一些动作方面的特征等。

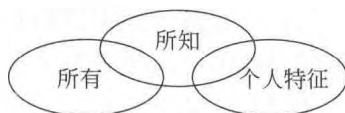


图 15-4 身份证明的基本途径

根据安全水平、系统通过率、用户可接受性、成本等因素, 可以选择适当的组合设计实现一个自动化身份证明系统。

身份证明系统以合法用户遭拒绝的概率 (即拒绝率 (False Rejection Rate, FRR) 或虚报率 (I 型错误率)) 和非法用户伪造身份成功的概率 (即漏报率 (False Acceptance Rate, FAR) (II 型错误率)) 作为服务质量评价指标。为了保证系统有良好的服务质量, 要求 I 型错误率要足够小; 为保证系统的安全性, 要求 II 型错误率也要足够小。这两个指标常常是相悖的, 应根据不同的用途进行适当的折中选择, 如为了安全 (降低 FAR) 牺牲一点服务质量 (增大 FRR)。设计时除了考虑安全性外, 还要考虑经济性和可用性。

15.2

口令认证系统

15.2.1 概述

口令是一种根据已知事物验证身份的方法, 也是一种被广泛使用的身份验证方法。在现实世界中, 采用口令的例子不胜枚举: 如中国古代调兵用的虎符、阿里巴巴打开魔洞的“芝麻”密语、军事上采用的各种口令及现代通信网的访问控制协议。大型应用系统的口令通常采用一个长为 5~8 个字符的字符串。口令的选择原则为: ①易记; ②难以被别人猜中或发现; ③能抵御蛮力破解分析。在实际系统中, 需要考虑和规定口令的选择方法、使用期限、字符长度、分配和管理及在计算机系统内的存储保护等。根据系统对安全水平的要求, 用户可选择不同的口令方案。

在口令的选择方法上, Bell 实验室也做过一些试验。结果表明, 让用户自由选择自己的口令, 虽然易记, 但往往带有个人特点, 容易被别人推测出来。而完全随机选择的字符串又太难记忆, 难以被用户接受。较好的办法是以可拼读的字节为基础构造口令。例如, 若限定字符串的长度为 8 字符, 在随机选取时可有 2.1×10^{11} 种组合; 若限定可拼读时, 可能的选取个数只为随机选取时的 2.7%, 但仍有 5.54×10^9 之多。而普通英语大词典中的字数不超过 2.5×10^5 个。

一个更好的办法是采用通行短语 (Pass Phrases) 代替口令, 通过密钥碾压 (Key Crunching) 技术, 如杂凑函数, 可将易于记忆的足够长的短语变换为较短的随机性密钥。

口令分发系统的安全性也不容忽视。口令可由用户个人选择, 也可由系统管理员选定或由系统自动产生。有人认为, 用户专用口令不应让系统管理员知道, 并提出一种实

现方法。用户的账号与他选定的护字符组合后，在银行职员看不到的地方输入系统，通过单向加密函数加密后存入银行系统中。当访问系统时，将账号和口令通过单向函数变换后送入银行系统，通过与存储的值相比较进行验证。若用户忘记了自己的口令，可以再选一个并重新办理登记手续。当前，银行（如中国银行等）通常为用户颁发一次性口令令牌，用户持令牌进行网上银行的操作，此举使网上银行的安全性大大提高。有关一次性口令系统的内容将在 15.4 节中进行详细介绍。

图 15-5 给出了一种单向函数检验口令框图。有时系统需要双向认证，即不仅系统要检验用户的口令，用户也要检验系统的口令。在这种情况下，如何确保一方在另一方给出口令之前不会受到对方的欺骗是一个关键问题。图 15-6 给出一种双方互换口令的安全验证方法：甲、乙分别以 P 、 Q 作为护字符。为了验证，他们彼此都知道对方的口令，并通过一个单向函数 f 进行响应。例如，若甲要联系乙，甲先选一随机数 x_1 送给乙，乙用 Q 和 x_1 计算 $y_1=f(Q, x_1)$ 送给甲，甲将收到的 y_1 与自己计算的 $f(Q, x_1)$ 进行比较，若相同，则验证了乙的身份；同样，乙也可选随机数 x_2 送给甲，甲将计算的 $y_2=f(P, x_2)$ 回送给乙，乙将所收到的 y_2 与他自己计算的值进行比较，若相同，就验证了甲的身份。

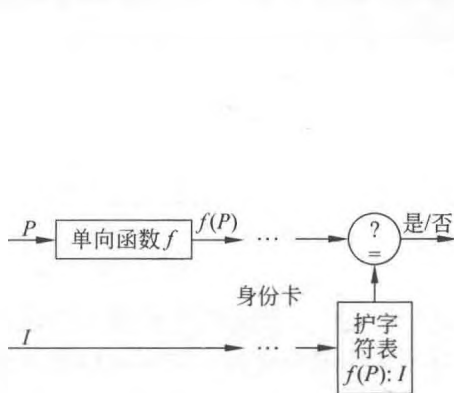


图 15-5 一种单向函数检验口令框图

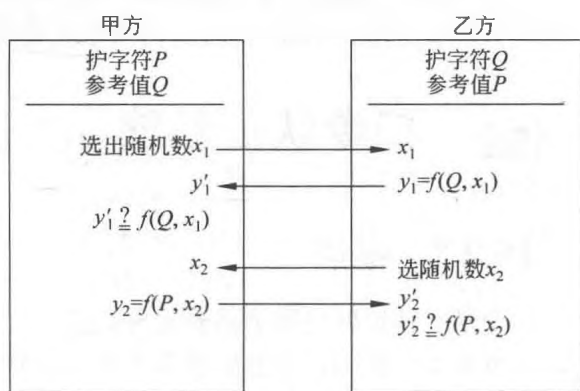


图 15-6 一种双方互换口令的安全验证方法

为了解决因口令短而造成的安全性低的问题，常在口令后填充随机数，如在 16b（4 位十进制数字）护字符后附加 40b 随机数 R_1 ，构成 56b 数字序列进行运算，形成

$$y_1=f(Q, R_1, x_1) \quad (15-1)$$

这会使安全性大为提高。

上述方法仍未解决谁先向对方提供口令和随机数的难题。

可变口令也可由单向函数来实现。这种方法只要求交换一对口令而不是口令表。令 f 为某个单向函数， x 为变量。定义

$$f^n(x)=f(f^{n-1}(x)) \quad (15-2)$$

甲取随机变量 x ，并计算

$$y_0=f^n(x) \quad (15-3)$$

送给乙。甲将 $y_1=f^{n-1}(x)$ 作为第一次通信用口令。乙收到 y_1 后计算 $f(y_1)$ ，并检验与 y_0 是否相同，若相同，则将 y_1 存入备用。甲第二次通信时发 $y_2=f^{n-2}(x)$ 。乙收到 y_2 后，计算 $f(y_2)$ ，并检验是否与 y_1 相同，依此类推。这样一直可用 n 次。若中间数据丢失或出错，

甲可向乙提供最近的取值,以求重新同步,而后乙可按上述方法进行验证。

一个更安全但较费时的身份验证方法是询问法 (Questionaries)。业务受理者可利用他知道而别人不知道的一些信息向申请用户进行提问。他可提问一系列互不相关的问题,如你原来的中学校长是谁? 祖母多大年纪? 某作品的作者是谁? 等。回答不必都完全正确,只要足以证实用户身份即可。应选择一些易于记忆的事务并让验证者预先记住。这只适用于安全性高又允许耗时的情况。

15.2.2 口令的控制措施

(1) 系统消息 (System Message)。一般系统在联机和脱机时都显示一些礼貌性用语,而成为识别该系统的线索,因此这些系统应当可以抑制这类消息的显示,口令当然更不能显示。

(2) 限制试探次数。不成功传送口令一般限制为 3~6 次,超过限定试验次数,系统将该用户 ID 锁定,直到重新认证授权后再开启。

(3) 口令有效期。限定口令的使用期限。

(4) 双口令系统。首先输入联机口令,在接触敏感信息时还要输入一个不同的口令。

(5) 最小长度。限制口令至少为 6~8B 以上,防止猜测成功的概率过大,可采用掺杂 (Salting) 或采用通行短语 (Passphrase) 等加长和随机化。

(6) 封锁用户系统。可以封锁长期未联机用户或口令超过使用期用户的 ID 号,直到用户重新被授权。

(7) 根 (Root) 口令的保护。根口令是系统管理员访问系统时所用的口令,由于系统管理员被授予的权力远大于一般用户,因此管理员口令自然成为攻击者的攻击目标。因此,管理员口令在选择和使用中要倍加保护。管理员口令通常必须采用十六进制字符串,不能通过网络传送,并且要经常更换。

(8) 系统生成口令。有些系统不允许用户自己选定口令,而是由系统生成和分配。系统如何生成易记忆又难以被猜中的口令是要解决的一个关键问题。如果口令难以记忆,则用户要将其写下来,这反而增加了口令泄漏的风险;若系统的口令生成算法被窃,则更加危险,因为这将危及整个系统的安全。

15.2.3 口令的检验

1. 反应法 (Reactive)

利用一个程序 (Cracker) 让被检口令与一批易于猜中的口令表中的成员逐个比较,若都不相符,则通过。

ComNet 的反应口令检验 (Reactive Password Checking) 程序大约可以猜出近 1/2 的口令。Raleigh 等设计的口令验证系统 CRACK 利用网络服务器分析口令。美国 Purdue 大学研制出了 OPUS 口令分析选择软件。

这类反应检验法的缺点是: ①检验一个口令太费时间,一个攻击者可能要用几小时甚至几天来攻击一个口令; ②现用口令都有一定的可猜性,但如果直到采用反应检验后用户才更换口令,会存在一定的安全隐患。

2. 支持法（Proactive）

用户先自行选择一个口令。当用户第一次使用该口令时，系统利用一个程序检验其安全性。如果口令易于猜中，则拒绝登录，并请用户重新选一个口令。程序通过准则要考虑在可猜中性与安全性之间取得折中：若检验算法太严格，则造成用户所选口令屡遭拒绝，从而招致用户抱怨；如果检验算法太宽松，则很易猜中的口令也能通过检验，这会影响系统的安全性。

15.2.4 口令的安全存储

1. 一般方法

(1) 用户的口令多以加密形式存储，入侵者要得到口令，必须知道加密算法和密钥。算法可能是公开的，但密钥只有管理员才知道。

(2) 许多系统可以存储口令的单向杂凑值，入侵者即使得到此杂凑值也难以推算出口令的明文。

2. UNIX 系统中的口令存储

口令为 8 个字符，采用 7b ASCII 码，即 56b 串，加上 12b 填充（一般为用户输入口令的时间信息）。第一次输入 64b 全“0”数据进行加密，第二次则以第一次加密结果作为输入数据，迭代 25 次，将最后一次输出变换成 11 个字符（其中，每个字符是 A~Z，a~z，0~9，“0”，“1”等共 64 个字符之一）作为口令的密文，如图 15-7 所示。

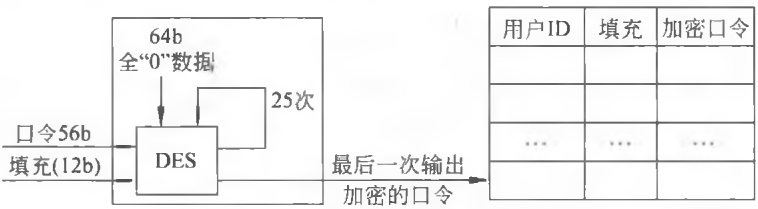


图 15-7 UNIX 系统中的口令存储

检验时，用户发送 ID 和口令。UNIX 系统由 ID 检索出相应填充值（12b），并与口令一起送入加密装置算出相应密文，与从存储器中检索出的密文进行比较，若一致则通过检验。

3. 用智能卡令牌（Token）产生一次性口令

这种口令在本质上是由一个随机数生成器产生的，可以由安全服务器用软件生成，一般用于第三方认证，智能卡认证系统如图 15-8 所示。

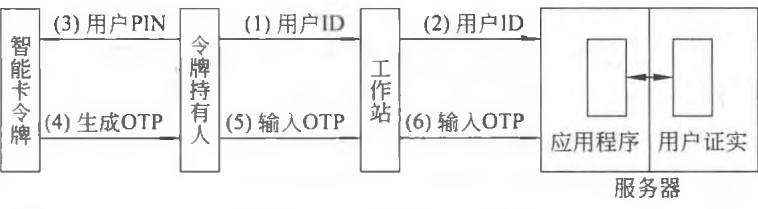


图 15-8 智能卡认证系统

利用令牌产生一次性口令的优点是：①即使口令被攻击者截获也难以使用；②用户需要输入 PIN（只有持卡人才知道），因此，即使令牌被偷也难以用其进行违法活动。

如美国 Secure Dynamics Inc. 的 Secure ID 卡和 RSA 公司的 Secur ID 令牌等，均用来产生这类一次性口令。在后面，还会对一次性口令技术进行深入讨论。

15.3 个人特征的身份证明技术

在对安全性要求较高的系统中，由护字符和持证等方案提供的安全性不能满足要求，因为护字符可能被泄漏、证件可能丢失或被伪造。更高级的身份验证方案是根据被授权用户的个人生物特征来进行认证，这是一种可信度高而又难以伪造的身份验证方法。这种方法早已用于刑事案件的侦破中。自 1870 年开始，法国人采用 Bertillon 体制对人的前臂、手指长度、身高、足长等进行测试，它根据人体测量学（Anthropometry）进行身份验证。这种方法比指纹还精确，自使用以来还未发现过两个人的数值完全相同的情况。伦敦市警厅已于 1900 年采用了这一体制。

新的生物统计学（Biometrics）方法正在成为实现个人身份认证最简单而安全的方法。它利用个人的生物特征来实现身份认证。一个人的生物特征包括很多方面，有静态的，也有动态的，如容貌、肤色、发长、身材、姿势、手印、指纹、脚印、唇印、颅相、口音、脚步声、体味、视网膜、血型、遗传因子、笔迹、习惯性签字、打字韵律及在外界刺激下的反应等。当然，所采用的认证方式还要为被验证者所接受。有些检验项目，如唇印、足印等虽然认证率很高，但因难于被人们接受而不能广泛使用。有些生物特征可由人工认证，有些则须借助仪器，当然，不是所有场合都能采用生物特征识别的方式。这类物理认证还可与报警装置配合使用，可作为一种“诱陷模式”（Entrapment Module）在重要入口进行接入控制，使敌手的风险加大。由于个人特征具有因人而异和随身携带的特点，所以它不会丢失且难以伪造，非常适用于个人身份认证。

有些个人特征会随时间变化。验证设备必须有一定的容差。容差太小可能导致系统不能正确认出合法用户，造成虚警概率过大；容差太大则可能使敌手成为漏网之鱼。在实际系统设计中，要在这两者之间做出最佳折中选择。有些个人特征则具有终生不变的特点，如 DNA、视网膜、虹膜、指纹等。

目前，这类产品由于成本较高而尚未得到广泛采用，但是在一些重要的部门，如银行、政府、医疗、商业、军事、保密、机场等系统中，已经逐步得到应用。下面介绍几种研究较多且具有实用价值的身份验证体制。

15.3.1 手书签字验证

传统的协议、契约等都以手书签字生效。发生争执时，则由法庭判决，一般都要经过专家鉴定。由于每个人的签名动作和字迹具有明显的个性，因此手书签名可作为身份

验证的可靠依据。

由于形势发展的需要，机器自动识别手书签字的研究得到了广泛的重视，成为模式识别中的重要研究课题之一。机器识别的任务有二：一是签字的文字含义；二是手书的字迹风格。后者对于身份验证尤为重要。识别可从已有的手迹和签字的动力学过程中的个人动作特征出发来实现。前者为静态识别，后者为动态识别。静态验证根据字迹的比例、倾斜的角度、整个签字布局及字母形态等实现；动态验证根据实时签字过程进行证实。这要测量和分析书写时的节奏、笔画顺序、轻重、断点次数、环、拐点、斜率、速度、加速度等个人特征。英国物理实验室研制出 VERISIGN 系统，它采用一种叫做 CHIT 的书写垫记录签字时笔尖的运动状况，并进行分析得出结论。IBM 公司的手书验证研究一种采用加速度动态识别方法，但分辨率不高，在增加了测量书写笔压力变化的装置后，性能得到了大大改进。I 型错误率为 1.7%，II 型错误率为 0.4%，目前已有实用。Cadix 公司为电子贸易设计了笔迹识别系统。笔迹识别软件 Penop 可用于识别委托指示、验证公司审计员身份及税收文件的签字等，并已集成到 Netscape 公司的 Navigation 和 Adobe 公司的 Acrobat Exchange 软件中。Penop 成为软件安全工具的新成员，它将对 Internet 的安全发挥重要作用。

可能的伪造签字类型有两种：一种是不知真迹时按得到的信息（如银行支票上印的名字）随手签的字；另一种是已知真迹时的模仿签字或映描签字。前者比较容易识别，而对后者的识别则相对困难。

签字系统作为接入控制设备的组成部分时，应先让用户书写几个签名进行分析，提取适当的参数存档备用。对于个别签字一致性极差的人要特殊对待，如采用容错值较大的准则处理其签字。

15.3.2 指纹验证

指纹验证早就用于契约签证和侦察破案中。由于没有两个人的指纹完全相同，相同的可能性不到 10^{-10} ，而且指纹形状不随时间而变化、提取指纹作为永久记录存档又极为方便，因此指纹识别成为进行身份验证的准确而可靠的手段。每根手指的纹路可分为两大类：环状和涡状。每类又根据其分叉等细节分成 50~200 个不同的图样。通常由专家来进行指纹识别。近年来，许多国家都在研究计算机自动识别指纹图样。将指纹验证作为接入控制手段会大大提高计算机系统的安全性和可靠性。但由于指纹验证常与犯罪联系在一起，人们从心理上不愿接受按指纹。目前，由于机器识别指纹的成本已经大大降低，所以高端的笔记本已经开始使用指纹识别进行身份认证。

1984 年，美国纽约州 North White Plain 的 Fingerprintmatrix 公司宣称其研制出一种指纹阅读机（Ridge Reader）和个人接触证实（Personal Touch Verification, PTV）系统，可用于计算机网络中，参考文件库在主机之中。系统特点如下：①阅读机的体积约为 0.028m^3 ，内有光扫描器；②新用户注册需 3~5 分钟；③从一个人的两个手指记录图样需两分钟，存储量为 500~800 字节；④每次访问不超过 5 秒；⑤能自动恢复破损的指纹；⑥ I 型错误率小于 0.1%；⑦ II 型错误率小于 0.001%；⑧可选择俘获和存储入侵者的指纹。每套

设备成本为 6000 美元。Identix 公司的产品 Identix System 已在四十多个国家使用,包括美国五角大楼的物理入口的进出控制系统。

美国的 FBI 已成功地将小波理论应用于压缩和识别指纹图样,将一个 10Mb 的指纹图样压缩成 500kb,大大减少了数百万指纹档案的存储空间和检索时间。

全世界有几十家公司经营和开发新的自动指纹身份识别系统 (AFIS),一些国家已经或正在考虑将自动指纹身份识别作为身份证或社会安全卡的有机组成部分,以有效地防止欺诈、假冒及一人申请多个护照等。执法部门、金融机构、证券交易、福利金发放、驾驶证、安全入口控制等将广泛采用 AFIS。

15.3.3 语音验证

每个人的语音都各有其特点,而人对于语音的识别能力是很强的,即使在强干扰下也能分辨出某个熟人的语音。在军事和商业通信中,常常根据对方的语音实现个人身份验证。长期以来,人们一直在研究如何用机器自动识别人说话。语音识别技术有着广泛的应用,其一就是用于个人身份验证。例如,将对每个人讲的一个短语所分析出来的全部特征参数存储起来,如果每个人的参数都不完全相同,就可实现身份验证。存储的语音特征称为语声纹 (Voice-print)。美国 Texas 仪器公司曾设计一个 16 个字集的系统;美国 AT&T 公司为拨号电话系统研制了一种语音口令系统 (Voice Password System, VPS),并为 ATM 系统研制了智能卡系统。这些系统均以语音分析技术为基础。

德国汉堡的 Philips 公司和西柏林的 Heinrich Hertz 研究所合作研制了 AUROS 自动说话人识别系统,该系统利用语音参数实现实用环境下的身份识别, I 型错误率为 1.6%, II 型错误率为 0.8%。在最佳状态下, I 型错误率为 0.87%, II 型错误率为 0.94%,明显优于其他方法。美国 Purdue 大学、Threshold Technology 公司等都在研究这类验证系统。目前,可以分辨数百人的语声纹识别系统的成本可降至 1000 美元以下。

电话和计算机的盗用是相当严重的问题,语声纹识别技术可用于防止黑客进入语音函件和电话服务系统。

15.3.4 视网膜图样验证

人的视网膜血管图样 (即视网膜脉络) 具有良好的个人特征。采用视网膜血管图样的身份识别系统已在研制中。其基本方法是利用光学和电子仪器将视网膜血管图样记录下来,一个视网膜血管的图样可压缩为小于 35B 的数字信息,然后可根据对图样的节点和分支的检测结果进行分类识别。被识别的人必须充分合作,允许采样。研究表明,识别验证的效果相当好。如果注册人数小于 200 万,其 I 型和 II 型识别的错误率都为 0,所需时间为秒级,在安全性要求很高的场合可以发挥作用。由于这种系统的成本较高,因此目前仅在军事系统和银行系统中采用。

15.3.5 虹膜图样验证

虹膜是巩膜的延长部分,是眼球角膜和晶体之间的环形薄膜,其图样具有个人特征,

可以提供比指纹更细致的信息。虹膜图样可以在 35~40cm 的距离范围内采集，比采集视网膜图样更方便，易为人所接受。存储一个虹膜图样需要 256B，所需的计算时间为 100ms。其 I 型和 II 型错误率都为 1/133 000。可用于安全入口、接入控制、信用卡、POS、ATM、护照等的身份认证。美国 IriScan Inc. 已研发出此种产品。

15.3.6 脸型验证

Harmon 等设计了一种用照片识别人脸轮廓的验证系统。对 100 个“好”对象识别结果正确率达百分之百。但对“差”对象的识别要困难得多，要求更细致的实验。对于不加选择的对象集合的身份验证几乎可达到完全正确。这一研究还扩展到对人耳形状的识别，而且耳形识别的结果令人鼓舞，可作为司法部门的有力辅助工具。目前有十几家公司从事脸型自动验证新产品的研制和生产。这些产品利用图像识别、神经网络和红外扫描探测人脸的“热点”进行采样、处理并提取图样信息。目前已开发出能存入 5000 个脸型、每秒可识别 20 人的系统。未来的产品可存入 100 万个脸型，但识别检索所需的时间将增加到两分钟。Microsoft 公司正在开发符合 Cyber Watch 技术规范的 True Face 系统，将用于银行等部门的身分识别系统中。Visionics 公司的面部识别产品 Facelt ARGUS 已用于网络环境中，其软件开发工具（SDK）可以集成到信息系统的软件系统中，作为金融、接入控制、电话会议、安全监视、护照管理、社会福利发放等系统的应用软件。

15.3.7 身份证明系统的设计

选择和设计实用身份证明系统并非易事。Mitre 公司曾为美国空军电子系统部评价过基地设施安全系统规划，并分析比较了语音、手书签字和指纹 3 种身份验证系统的性能。分析表明，选择评价这类系统的复杂性需要从很多方面进行研究。美国 NBS 的自动身份验证技术的评价指南提出了下述 12 个需要考虑的问题：

- （1）抗欺诈能力。
- （2）伪造容易程度。
- （3）对于设陷的敏感性。
- （4）完成识别的时间。
- （5）方便用户。
- （6）识别设备及运营的成本。
- （7）设备使用的接口数目。
- （8）更新所需时间和工作量。
- （9）为支持验证过程所需的计算机系统的处理工作。
- （10）可靠性和可维护性。
- （11）防护器材的费用。
- （12）分配和后勤支援费用。

总之，设计身份认证系统主要考虑 3 个因素：①安全设备的系统强度；②用户的可接受性；③系统的成本。

15.4

一次性口令认证

目前,随着人们生活中信息化水平的提高,网上支付、网上划账等网上金融交易行为随着电子商务的展开越来越普及,大量的重要数据存储在网络数据库中,并通过网络共享为人们的生活提供了方便,但是也带来了巨大的信息安全隐患和金融风险。黑客攻击的主要技术有以下几种:缓冲区溢出技术、木马技术、计算机病毒(主要是宏病毒和网络蠕虫)、分布式拒绝服务攻击技术、穷举攻击(Brute Force)、Sniffer 报文截获等。在大部分黑客技术文献和攻击日志中,我们发现一个很重要的相似特征:几乎没有多少攻击行为是针对协议和密码学算法的,最常见的攻击方式是窃取系统口令文件和窃听网络连接,以获取用户 ID 和口令。大部分攻击的主要目的是设法得到用户 ID 和用户密码,只要获得用户 ID 和密码,所有敏感数据将暴露无遗。因此,必须改进基于口令的登录和验证方法,以抵御口令窃取和搭线窃听攻击。

一次性口令认证就是在这一背景下出现的,它的主要设计思路是在登录过程中加入不确定因素,通过某种运算(通常是单向函数,如 MD-5 和 SHA)使每次登录时用户所使用的密码都不相同,以此增强整个身份认证过程的安全性。

根据不确定因素的选择不同,一次性口令系统可以分为不同的类型。下面将对现用的一次性口令方案进行详细介绍。

15.4.1 挑战/响应机制

在挑战/响应机制中,不确定因素来自认证服务器,用户要求登录时,服务器产生一个随机数(挑战信息)发送给用户;用户用某种单向函数将这个随机数进行杂凑后,转换成密码,并发送给服务器。服务器用同样的方法进行验算即可验证用户身份的合法性。

挑战/响应机制认证流程如图 15-9 所示。

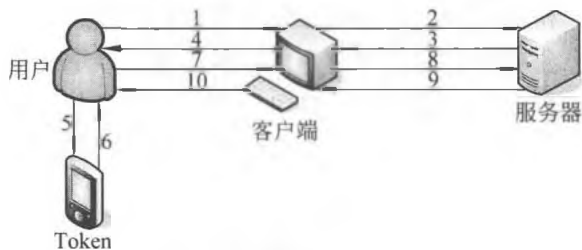


图 15-9 挑战/响应机制认证流程

- (1) 用户在客户端发起认证请求。
- (2) 客户端将认证请求发往服务器。
- (3) 服务器返回客户端一个挑战值。
- (4) 用户得到此挑战值。

- (5) 用户把挑战值输入给一次性口令产生设备（令牌）。
- (6) 令牌经过某一算法，得出一个一次性口令，返回给用户。
- (7) 用户把这个一次性口令输入客户端。
- (8) 客户端把一次性口令传送到服务器端。
- (9) 服务器得到一次性口令后，与服务器端的计算结果进行匹配，返回认证结果。
- (10) 客户端根据认证结果进行后续操作。

挑战/响应机制可以保证很高的安全性，但该机制存在一些缺陷：用户需多次手工输入数据，易造成较多的输入失误，使用起来十分不便；在整个认证过程中，客户端和服务端信息交互次数较多；挑战值每次都由服务器随机生成，使得服务器开销过大。

15.4.2 口令序列机制

口令序列（S/key）机制是挑战/响应机制的一种实现，原理如下。

在口令重置前，允许用户登录 n 次，那么主机需要计算出 $F_n(x)$ ，并保存该值，其中 F 为一个单向函数。用户第一次登录时，需提供 $F_{n-1}(x)$ 。系统计算 $F_n(F_{n-1}(x))$ ，并验证是否等于 $F_n(x)$ 。如果通过，则重新存储 $F_{n-1}(x)$ 。下次登录时，则验证 $F_{n-2}(x)$ ，依此类推。为方便用户使用，主机把 $F_{n-1}(x) \sim F_1(x)$ 计算出来，编成短语，打印在纸条上。用户只需按顺序使用这些口令登录即可。需要注意的是，纸条一定要保管好，不可遗失。由于 n 是有限的，用户用完这些口令后，需要重新生成新的口令序列。

该机制的致命弱点在于它只支持服务器对用户的单方面认证，无法防范假冒的服务器欺骗合法用户。另外一个缺点是，当迭代值递减为 0 或用户的口令泄漏后，则必须对 S/key 系统重新进行初始化。

15.4.3 时间同步机制

基于时间同步机制的令牌把当前时间作为不确定因素，从而产生一次性口令。

用户注册时，服务器会分发给用户一个密钥（内置于令牌中），同时服务器也会在数据库中保存这个密钥。对于每一个用户来说，密钥是唯一的。当用户需要身份认证时，令牌会提取当前时间，和密钥一起作为杂凑算法的输入，得出一个口令。由于时间在不断变化，其口令也绝不会重复。用户将口令传给服务器后，服务器运行同样的算法，提取数据库中用户对应的密钥和当前时间，算出口令，与用户传过来的口令匹配，然后将匹配结果回传给用户。图 15-10 就是基于时间同步机制的一次性口令认证过程。

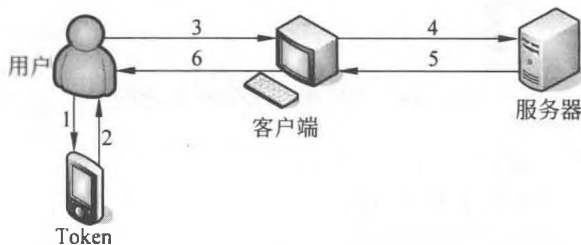


图 15-10 基于时间同步机制的一次性口令认证过程

- (1) 用户需要登录, 启动令牌。
- (2) 令牌显示出当前时间对应的一次性口令。
- (3) 用户把令牌产生的口令输入到客户端。
- (4) 客户端把口令传到服务器, 服务器进行认证。
- (5) 服务器把认证结果回传给客户端。
- (6) 客户端把认证结果显示出来。

时间同步机制的优点是: 用户使用简单、方便, 不需要像挑战/响应机制那样频繁地输入数据; 一次认证的通信量小, 通信效率高; 服务器的计算量不是很大。

但是时间同步机制要求用户的手持令牌和服务器的时钟偏差不能太大, 所以对设备的时钟精度要求比较高, 设计成本较高。为此, 在服务器端设置一个窗口, 例如, 如果令牌的时间单位是 1 分钟, 即令牌上的密码 1 分钟改变 1 次, 这时候考虑到令牌时钟和服务器时钟的偏差, 服务器端在进行认证的时候, 可以把时间窗口设置得略大一些, 服务器可以计算出该用户对应的前 1 分钟、当前分钟、后 1 分钟的 3 个口令, 所以只要用户传过来的口令是这 3 个口令中的任意一个, 服务器都会通过认证。

15.4.4 事件同步机制

事件同步机制又名计数器同步机制。基于事件同步的令牌将不断变化的计数器值作为不确定因素, 从而产生一次性口令。下面分两个方面对事件同步机制进行介绍。

1. 事件同步机制的认证过程

用户注册时, 服务器会产生一个密钥 Key (Key 是唯一的) 和一个已初始化的计数器 (下文中用 Counter 代表计数器的值), 并一起注入到用户手持的令牌中, 同时服务器保存 Key 和 Counter 到数据库中。当用户需要身份认证时, 用户触发令牌上的按钮, 令牌中的 Counter 加 1, 和预先注入的 Key 一起作为一个杂凑函数的输入, 生成一个口令; 用户把这个口令发送给服务器, 服务器端根据用户名在数据库中找到相应的 Key 和 Counter, 用同样的杂凑函数进行运算, 将产生的结果和用户发送过来的口令相匹配, 然后返回认证结果。如果认证成功, 服务器端的 Counter 值加 1, 否则 Counter 不变。

2. 事件同步机制的重同步方法

事件同步机制的一个明显不足就是用户和服务器端很容易失去同步, 例如, 用户不小心或故意按了令牌上的按钮, 但不进行认证, 令牌的 Counter 就会加 1。由于服务器上的 Counter 还是原来的值, 因此服务器和令牌就失去了同步。为了解决这个问题, 服务器端设置了一个窗口值 (ewindow), 当用户使用令牌产生一次性口令登录服务器时, 服务器会在此窗口范围内逐一匹配用户发送过来的口令, 只要在窗口内的任何一个值匹配成功, 服务器就会返回认证成功信息, 并且更改数据库中的计数器值, 使服务器和令牌再次同步。令牌重同步过程如图 15-11 所示。

显然, 出于安全性的考虑, 这个 ewindow 的值不能设置得太大, 如果产生的一次性口令是 6 位十进制数, 这个值的范围最好是 5~10 之间。但是还有一种极端情况: 用户把令牌当成了玩具, 不停地去触发事件, 使令牌的 Counter 远远超前于服务器的 Counter,

这样，ewindow 就失去了效用，就要依靠另外一个窗口值（rwindow）来重同步。rwindow 和 ewindow 一样，也规定了窗口范围，不过这个窗口要比 ewindow 的窗口大得多（对 6 位十进制口令来说，这个窗口的值大概在 50~100 之间）。如果用户令牌上的计数器超出了 ewindow 的范围，但还没有超出 rwindow 的范围，这时服务器会启用 rwindow 机制：用户只要连续输入两个在 rwindow 范围内的一次性口令，验证也会成功；但是如果用户不停地把玩令牌，使令牌的 Counter 超过了 rwindow 的范围，那就别无他法，用户只能拿着相关证件去注册中心办理重同步业务了。

事件同步机制类似于时间同步机制，用户操作简单；一次认证过程通信量小；可以防止小数攻击；服务器计算量稍大；系统实现比较简单，对设备的时钟精度没有要求。

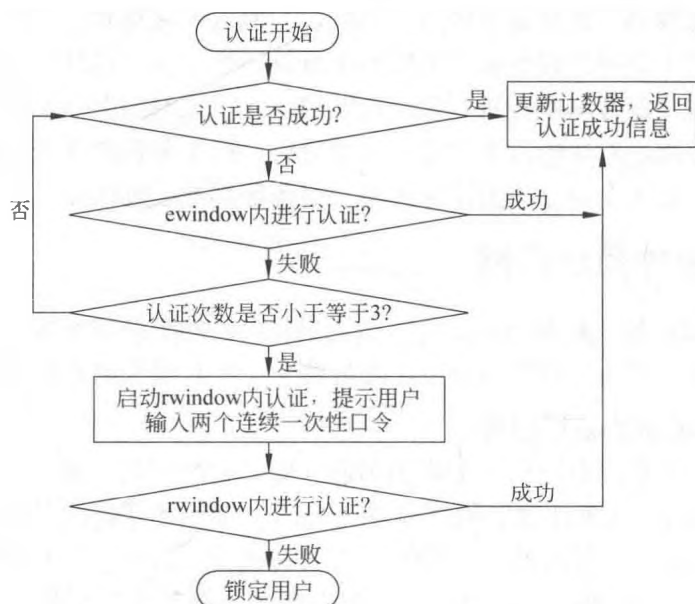


图 15-11 令牌重同步过程

15.4.5 几种一次性口令实现机制的比较

以上介绍了几种当前比较流行的一次性口令实现机制，下面对这几种机制在认证过程中的通信量、系统实现复杂度、机制安全性和服务器计算量等几个方面做出比较，如表 15-1 所示。

表 15-1 一次性口令实现机制的比较

机 制	通 信 量	系统实现复杂度	机制安全性	服务器计算量
挑战/响应	较大	较简单	较差	较大
S/key	较大	较简单	较差	较大
时间同步	较小	较复杂	较好	较小
事件同步	较小	较简单	较好	适中

从表 15-1 中可以看出，时间同步和事件同步的优势比较明显，目前市场上很多公司

的产品采用的大都是基于时间同步和事件同步的方案。

15.5 基于证书的认证

15.5.1 简介

近年来，人们越来越多地使用基于数字证书的认证机制。FIPS-196 标准对基于证书的认证操作进行了详细的说明。通过第 3 章的学习，我们已经知道，在 PKI 中，服务器和客户机要验证对方的数字证书才可以进行相互认证。

基于证书的认证机制比基于口令的认证机制更加安全，因为这种认证是靠“用户拥有某种东西”而不是靠“用户知道什么”来实现认证的。登录时，用户要通过网络向服务器发送证书（与登录请求一起发送）。服务器中有证书的副本，可以用于验证证书是否有效。但是，认证的过程并非如此简单。这里存在冒用他人证书进行登录的问题。例如，在 Alice 不知情的情况下，Bob 把 Alice 的证书（其实就是一个计算机文件）复制到其存储介质（如 U 盘）上，然后以 Alice 的身份登录服务器。

可以看出，这里存在的主要安全问题是滥用别人的证书。在实际应用中，如何防止证书的滥用问题呢？要解决这个问题，就必须把基于证书的认证变成双因子认证。也就是说，要在基于证书的认证基础上，加上基于口令的认证。

15.5.2 基于证书认证的工作原理

基于证书的认证过程分为以下几个步骤。

1. 生成、存储与发布数字证书

CA 为每个用户生成数字证书，并将其发给相应的用户。此外，服务器数据库中以二进制格式存储证书的副本，以便用户登录时验证用户的证书。用户证书的生成、存储与发布过程如图 15-12 所示。

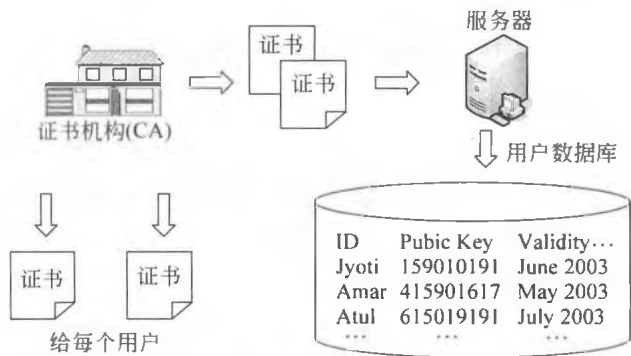


图 15-12 数字证书的生成、存储与发布过程

2. 用户发出登录请求

在登录服务器时，用户发送用户名和数字证书至服务器，如图 15-13 所示。

3. 服务器随机生成挑战值

当服务器收到用户的用户登录请求时，首先验证证书，检查用户是否有效。如果无效，则向用户返回出错信息；如果用户名有效，则服务器生成一个随机挑战值，并将其返回给用户。随机挑战值可以以明文形式传送到用户计算机，如图 15-14 所示。

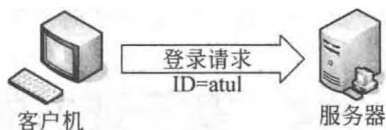


图 15-13 登录请求

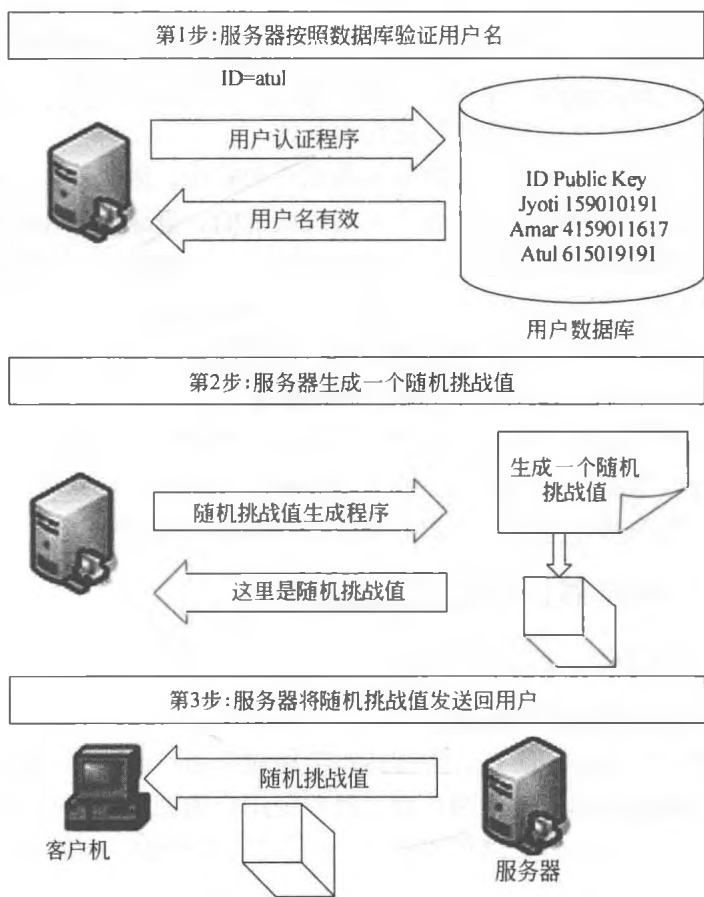


图 15-14 服务器生成随机挑战值并发给用户

4. 用户对随机挑战值签名

在用户收到来自服务器的挑战值后，用户就用其私钥对该挑战值签名。因此，用户要访问存储介质中的私钥文件。但是，私钥文件不是任何人都可以访问的。实际上，可以使用口令来限制对私钥文件的访问，从而保护私钥。因此，只有当用户输入正确的口令时，才能打开私钥文件，如图 15-15 所示。

用户输入正确口令后，应用程序打开用户的私钥文件，并用此私钥对挑战值进行签名。实际上，正确的做法是在签名运算之前对挑战值进行杂凑运算，以获得固定长度的杂凑值，再对杂凑值进行签名；然后，用户计算机将此签名发送给服务器。以上过程如图 15-16 所示，为了叙述简单，图 15-16 中省略了杂凑运算的步骤。

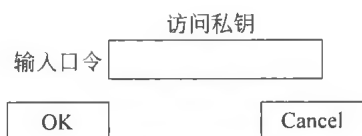


图 15-15 输入正确的口令打开私钥文件

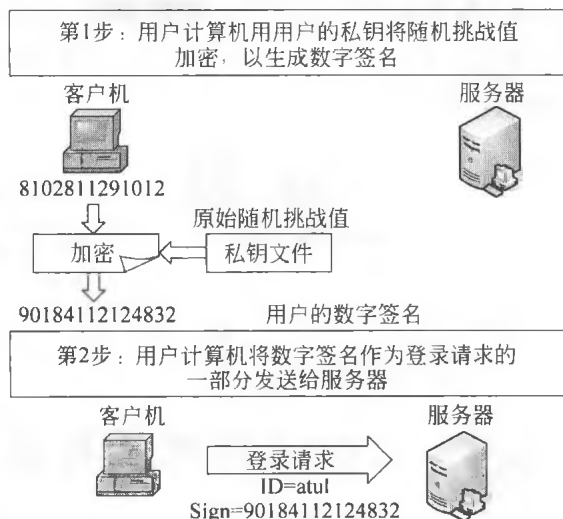


图 15-16 用户计算签名

服务器在收到用户签名后，立即对签名进行验证。为此，服务器首先应从用户数据库中取得用户的公钥，再用此公钥验证此签名，并恢复出挑战值。最后，服务器比较恢复的挑战值与原先发送给用户的挑战值（实际上是比较两个挑战值的杂凑值）是否相同。以上过程如图 15-17 所示。

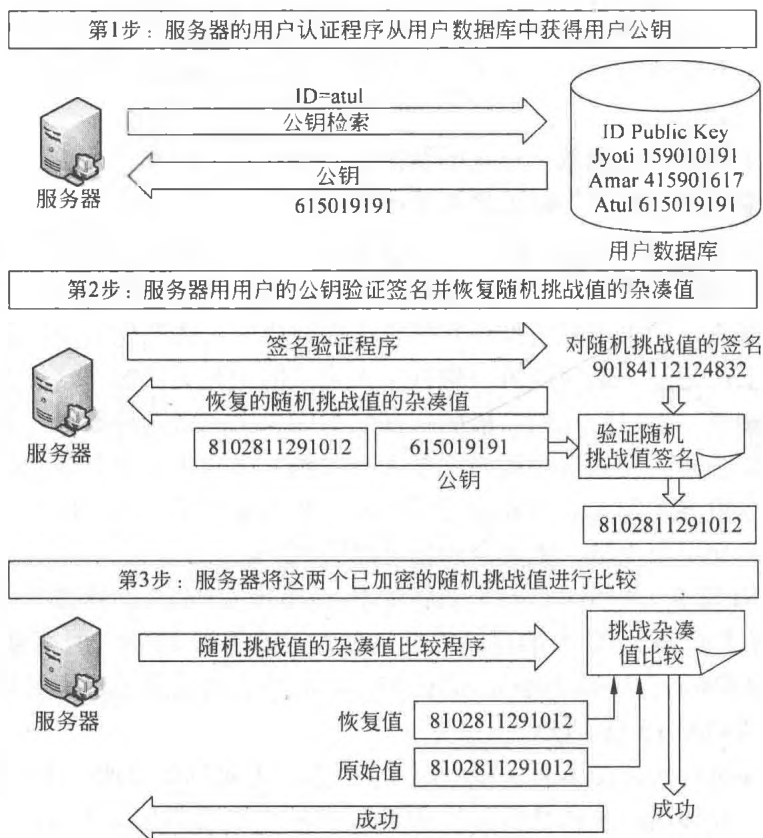


图 15-17 服务器比较两个挑战值的杂凑值

5. 服务器向用户返回相应的消息

最后，根据上述验证是否通过，服务器向用户返回相应的消息，以通知用户操作是否成功，如图 15-18 所示。

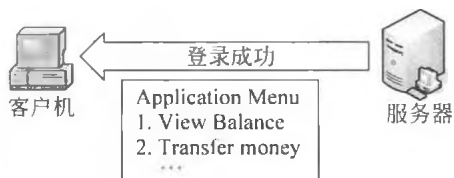


图 15-18 服务器向用户返回认证结果

15.6

智能卡技术及其应用

令牌为个人持有物，可用其进行用户的身份认证。用户也可以持磁卡 and 智能卡进行身份认证。通常把这些卡称为身份卡，简称 ID 卡。早期的磁卡是一种嵌有磁条的塑卡，磁条上有 2~3 个磁道，记录有关个人信息，用于机器读入识别。它由高强度、耐高温的塑料制成，防潮、耐磨、柔韧、便于携带。发达国家在 20 世纪 60 年代就开始在各类 ATM 上推广使用信用卡。国际标准化组织曾对卡和磁条的尺寸布局提出建议。卡的作用类似于钥匙，用来开启电子设备，这类卡常与个人识别号（PIN）一起使用。当然，最好将 PIN 记在心里而不要写出来，但对某些拥有多种卡的用户来说，要记住所有卡的 PIN 也不容易。

这类卡易于制造，且磁条上记录的数据易于被转录，因此应设法防止卡的复制。人们已发明了许多“安全特征”以改进智能卡的安全性，如采用水印花纹或在磁条上添加永久不可擦掉的记录，用以区分真伪，使敌手难以仿制。也可采用夹层带（Sandwich Tape）的卡，这种卡将高矫顽磁性层和低矫顽磁性层粘在一起，使低矫顽磁性层靠近记录磁头。记录时用强力磁头，使上下两层都录有信号；而读出时，先产生一个消磁场，洗掉表面低矫顽磁性层上的记录，但对高矫顽磁性层上记录的记号无影响。这种方案可以防止用普通磁带伪造塑卡，也可防止用一般磁头在偷得的卡上记录伪造数据。但这种卡的安全性不高，因为高强磁头和高矫顽磁带并非太难得到。信用卡缺少有效的防伪和防盗等安全保护措施，全世界的发卡公司和金融系统每年都因安全事件而造成巨大损失。因此，人们开始研究和更先进、更安全和更可靠的 IC 卡。

IC 卡又称有源卡（Active Card）或智能卡（Smart Card）。它将微处理器芯片嵌在塑卡上代替无源存储磁条。IC 卡的存储信息量远大于磁条的 250B，且有处理功能。IC 卡上的处理器有 4KB 的程序和小容量 EPROM，有的甚至有液晶显示和对话功能。智能卡的工作原理框图如图 15-19 所示。

智能卡的安全性比无源卡有了很大提高，因为敌手难以改变或读出卡中所存的数据。在智能卡上有一存储用户永久性信息的 ROM，在断电情况下信息不会消失。每次使用卡进行的交易和支出总额都被记录下来，因而可确保不能超支。卡上的中央处理器对输入、

输出数据进行处理。卡中存储器的某些部分信息只由发卡公司掌握和控制。通过中央处理器,智能卡本身就可检验用卡人所提供的任何密码,将它同储于秘密区的正确密码进行比较,并将结果输出到卡的秘密区中,秘密区还存有持卡人的收支账目,以及由公司选定的一组字母或数字编号,用以确定其合法性。存储器的公开区存有持卡人姓名、住址、电话号码和账号,任何读卡机都可读出这些数据,但不能改变它。系统的中央处理机也不会改变公开区内的任何信息。人们正在研究如何将更强的密码算法嵌入智能卡系统,进行认证、签字、杂凑、加/解密运算,以增强系统的安全性。

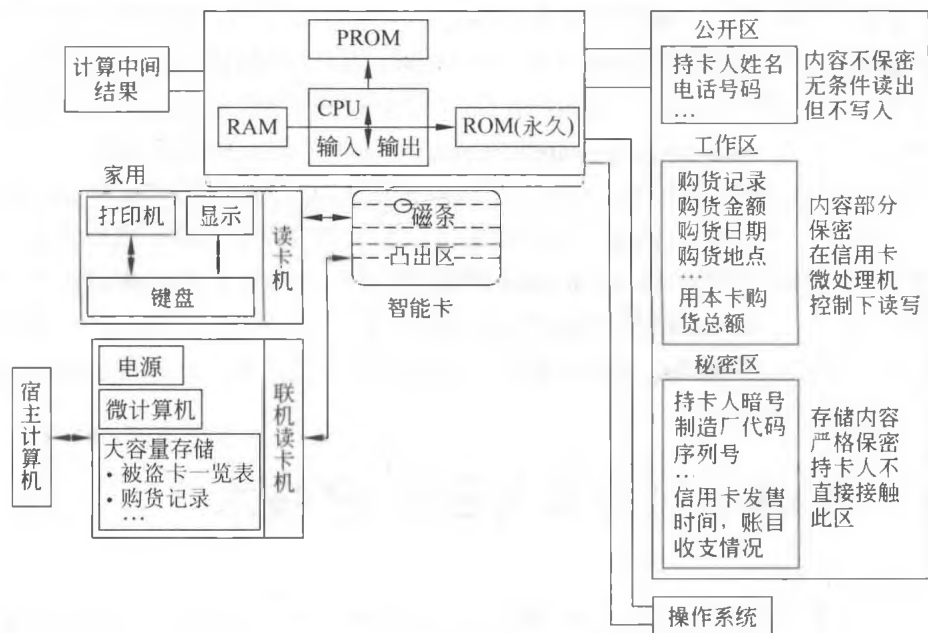


图 15-19 智能卡的工作原理框图

智能卡发行时都要经过个人化（Personalization）或初始化（Initialization）阶段，其具体内容因卡的种类不同和应用模式不同而异。发卡机构根据系统设计要求将应用信息（如发行代码等）和持卡人的个人信息写入卡中，使该智能卡成为持卡人的专有物，并用于特定的应用模式。一般 IC 卡的个人化有以下几方面的内容：①软、硬件逻辑的格式化；②写入系统应用信息和个人有关信息；③在卡上印制持卡人名称、发行机构的名称、持卡人的照片等。

现在，IC 卡已经广泛地应用于电子货币、电子商务、劳动保险、医疗卫生等对安全性要求更高的系统中。除了银行系统外，在付费电视系统中也有应用。付费广播电视系统每 20s 改变一次加密电视节目信号的密钥，用这类智能卡可以同步地更换解密密钥，以正常收看加密频道的节目。随着智能卡的存储容量和处理功能的进一步加强，它将成为身份认证的一种工具，可进一步扩大其应用范围，如制作电子护照、二代身份证、公交一卡通、校园一卡通、电话/电视计费卡、个人履历记录、电子门禁系统等。在不久的将来，个人签字、指纹、视网膜图样等信息就可能存入智能卡，成为身份验证的更有效手段。未来的智能卡所包含的个人信息将越来越多，人们将智能卡作为高度个人化的持证来实施身份认证。

智能卡的安全涉及许多方面，如芯片的安全技术、卡片的安全制造技术、软件的安全技术及安全密码算法和安全可靠协议的设计。智能卡的管理系统的安全设计也是其重要组成部分，对智能卡的管理包括制造、发行、使用、回收、丢失或损坏后的安全保障及补发等。此外，智能卡的防复制、防伪造等也是实际工作中要解决的重要课题。

目前，全球生产制造 IC 卡的公司很多。据统计，国内生产 IC 卡的公司有二百多家，国外的主要厂商有 23 家，销量最大的要属荷兰的恩智浦（NXP）公司、德国的英飞凌（Infineon）公司、瑞士的 LEGIC 公司等。我国 IC 卡的发行量已经达到 9.39 亿张，其中 9 亿多张为非接触式卡，2100 万多张为接触式卡。2008 年 2 月，荷兰政府发布了一项警告，指出目前广泛应用的恩智浦公司生产的 Mifare RFID 产品被破解。德国学者 Henryk Plotz 和弗吉尼亚大学的在读博士 Karsten Nohl 宣称破解了 Mifare Classic 的加密算法。在第 24 届黑客大会（Chaos Communications Congress）上，两人介绍了 Mifare Classic 的加密机制，并且首次公开宣布针对 Crypto-1 的破解分析方法，他们展示了破解 Mifare Classic 的手段。Nohl 在一篇针对 Crypto-1 加密算法进行分析的文章中声称，利用普通的计算机在几分钟之内就能够破解出 Mifare Classic 的密钥，同时还表示他们将继续致力于这个领域的深入研究。由于我国的很多信息系统均采用了恩智浦公司的 Mifare 卡，因此该卡的破解也对我国很多采用 Mifare 卡的系统构成了严重的安全威胁，此事件已经引起我国各相关部门的高度重视。

15.7 AAA 认证协议与移动 IP 技术

移动 IP 技术是为了实现 TCP/IP 网络用户全方位、跨安全域移动或漫游而采用的通信技术。采用移动 IP 技术，移动用户可以在基于 TCP/IP 的网络中随意跨域移动和漫游，不用修改计算机原来的 IP 地址就可继续享有原网络中的一切服务权限。

移动 IP 网络中的节点有 3 种类型：移动节点（Mobile Node, MN）、所属地代理（Home Agent, HA）和外地代理（Foreign Agent, FA）。移动 IP 网络架构示意图如图 15-20 所示。

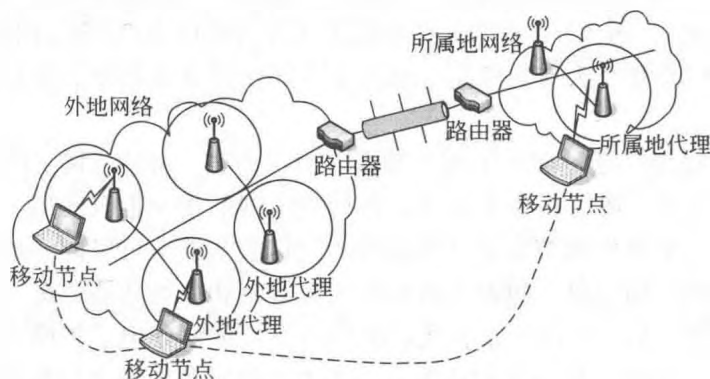


图 15-20 移动 IP 网络架构示意图

MN 为从所属地网络移动到外地网络的便携式终端。在 MN 移动到外地网络后，依然使用所属地网络的 IP 地址进行通信。HA 是所属地网络中的代理服务器，它保存有 MN 的位置信息。当 MN 移动到外地网络时，HA 能够将发往 MN 的数据包转发给 MN，并解析 MN 发回的数据包，转发给相应的通信节点。FA 是外地网络中的代理服务器，它能够将 HA 送来的数据包转发给 MN，并作为外地网络中移动终端的默认路由器。

移动 IP 有两类：基于 IPv4 的移动 IPv4 及基于 IPv6 的移动 IPv6。有关两种移动 IP 的工作机制请参见相关文献。移动 IP 的安全问题主要集中在两个方面：① 移动节点注册开始前各个实体间会话密钥的分发，以及彼此之间安全关联的建立；② 移动节点注册过程中轻量级保密与认证协议的设计与应用。将移动 IP 技术与 AAA（Authentication, Authorization, Accounting）技术相结合，可以解决移动 IP 的认证、授权及计费问题，为实现移动 IP 技术的大规模商业化应用奠定安全基础。

15.7.1 AAA 的概念及 AAA 协议

早期的 AAA 的概念是为了解决电话接入用户的身份认证、授权和计费而提出的。随着 Internet 的发展，IETF 工作组对原 AAA 协议进行了改进，提出了 RADIUS、DIAMETER 等新的 AAA 协议。下面对 AAA 的基本概念及其主流协议加以介绍。

1. AAA 的基本概念

认证（Authentication）是网络运营商在允许用户使用网络资源前对用户身份进行验证的过程。授权（Authorization）定义了用户在通过认证之后可以享受的服务。计费（Accounting）记录了用户使用资源的详细信息，这些原始信息可以用来生成计费账单或进行审计。图 15-21 给出了一个典型的 AAA 应用体系结构。远程用户通过电话线与网络接入服务器（NAS）连接，向 NAS 提出接入请求。NAS 接收这个请求，然后把用户的有关信息封装在 NAS 消息包中，发送给 AAA 服务器，由 AAA 服务器对这个请求进行认证，并返回相应的允许信息或拒绝信息。

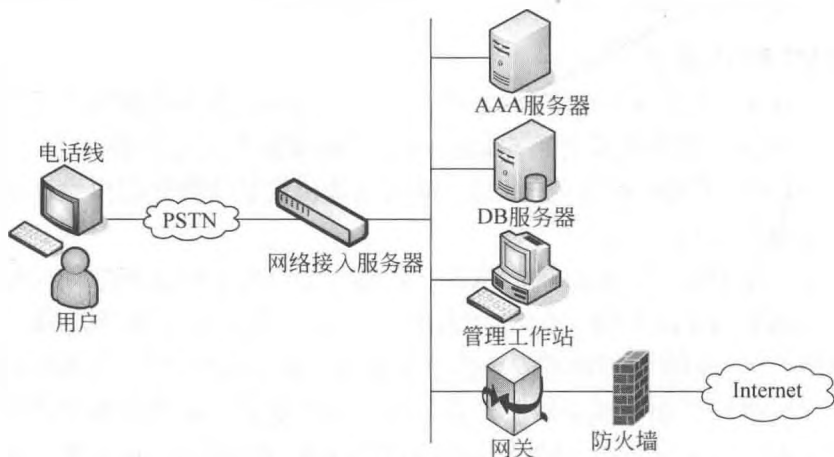


图 15-21 AAA 应用体系结构

AAA 这种分布式结构由服务器来完成认证、授权和计费工作，大大减轻了网关的压力，能够处理大量的用户请求，支持多种计费功能，可以对用户进行有效的控制，因而具有较强的生命力，在接入网中有着广泛的应用。

2. RADIUS 协议

RADIUS (Remote Access Dial-in User Service) 是为了在 NAS 和 RADIUS 服务器之间传递认证、授权和配置信息而设计的。它最初的设计思路是为电话接入访问服务的。NAS 通过 Modem 池或其他接口与外界相连。用户通过这些接口进入网络分享信息和资源。

RADIUS 实现了对通过这些接口进入的用户进行身份识别、授权和计费功能。这个协议基于客户/服务器模式，NAS 作为 RADIUS 的客户端运行，它负责将用户的信息传递给指定的 RADIUS 服务器，并将服务器的回应返回给用户，并为客户返回所有为用户提供服务所必需的配置信息。它还可以为其他 RADIUS 服务器或其他种类的认证服务器提供代理，在 RADIUS 服务器和 NAS 之间共享一对密钥，它们之间的通信受到这对密钥的保护，同时提供一定的完整性保护；对于一些敏感信息（如用户口令），还提供了机密性保护。

RADIUS 服务器能支持多种认证用户的方法，当用户提供了用户名和原始密码后，RADIUS 服务器可以支持点对点的 PAP 认证（PPP PAP），点对点的 CHAP 认证（PPP CHAP），以及 UNIX 的登录操作（UNIX Login）和其他认证。

RADIUS 的基本特征有如下两个。

(1) 采用客户/服务器 (Client/Server) 结构。通常情况下，NAS 作为 RADIUS 客户端和 RADIUS 服务器进行通信。而 RADIUS 服务器还可以扮演代理服务器的角色，可以把一个认证或计费请求转发给另一个 RADIUS 服务器。

(2) 采用属性方式增加功能。RADIUS 消息中使用属性来携带 AAA 信息。常见的属性有用户名、用户口令、封装协议、端口号、应用类型等。RADIUS 通过增加属性的方式来使 RADIUS 有更强的功能，这种方式使得 RADIUS 可以方便地对已有的系统进行扩充以增加新的功能，这大大增强了系统的可扩展性。

3. DIAMETER 协议

随着网络技术和应用需求的增长，新的网络服务不断涌现，用户需要一种安全的方式接入网络，网络也要对用户访问网络资源授权并进行计费。目前，这种 AAA 服务是由 RADIUS 或 TACACS+提供的，但是这些协议是为拨号用户设计的，无法有效地为新的业务提供 AAA 服务。

针对 RADIUS 的不足，IETF 的 AAA 工作组从 20 世纪 90 年代末期开始着手设计下一代的 AAA 协议 DIAMETER。DIAMETER 定义了一种 AAA 的体系结构，它由一个基本协议和一组扩展协议组成（如强安全性安全扩展、Mobile IP 扩展和 PPP 漫游扩展等）。通用的功能（如传输控制和流量控制）在基本协议中定义，而特定的应用功能在相应的扩展中进行说明。DIAMETER 基本协议提供了 AAA 协议所需的最基本要求，基本协议不能单独使用，必须与 DIAMETER 应用扩展相结合才能使用。

图 15-22 描述了逻辑上的 DIAMETER 的框架结构。Mobile IP 扩展为 Mobile IP 用户

提供 AAA 服务, 漫游扩展为漫游的 PPP 用户提供认证和计费支持, Mobile IP、PPP 漫游等应用的扩展协议建立在基本协议之上。

4. RADIUS 与 DIAMETER 比较

RADIUS 协议是在 20 世纪 90 年代初期设计的。随着 Internet 的飞速发展, 路由器和 NAS 在数量上和复杂性上都有了很大的提高, 各种新的网络服务也不断出现, 使得 RADIUS 越来越不适应现在的网络。主要表现在以下几个方面。

(1) 可携带的属性数据的长度太短

在 RADIUS 中, 包头的长度段只有 1B, 这就大大限制了一个 RADIUS 消息包的长度。随着网络的复杂化和服务的多样化, 用户的认证信息越来越多, 这意味着 AAA 协议信息包中需要携带更多的信息。

(2) 同时等待认证的用户数最多为 255 个

一个用户提出请求后, 在得到回复之前有一段等待时间, 在这段时间内, 用户处于等待状态, RADIUS 通过给用户分配一个 ID 号来识别同一时刻不同的等待用户, 但是用来标识 ID 号的字段只有 8b, 这就限制了同时等待回复的用户数只有 255 个, 这在某些大型网络中是远远不能满足要求的。

(3) 无法控制到服务器的流量

RADIUS 是使用 UDP 进行数据传输的, 而 UDP 没有流量控制, RADIUS 对此也没有进行扩展, 随着用户数量的增加, 服务器的负担越来越重, 没有流量控制机制, 将会造成大量的认证、计费请求涌向服务器, 造成服务器的瘫痪, 从而影响网络的稳定性和可靠性。

(4) 无重传过程和错误恢复支持

RADIUS 的客户端在一段时间之内没有收到回复时, 可以重发原来的请求。但是, 服务器端没有重发机制。如果服务器的回复丢失, 即使客户端的请求正确到达了, 也必须重新发送一个请求。

(5) 客户/服务器模式的协议

RADIUS 采用客户/服务器模式, 其缺点是服务器端只能被动地回答客户端的请求, 而不能主动发起一个认证过程, 这也大大限制了客户端和服务器端的通信能力。

(6) 安全性差

RADIUS 只对用户的口令部分进行加密, 而且无法防止重放攻击; 另外, RADIUS 支持代理功能, 即允许一个 RADIUS 服务器把一个请求转发给另一个 RADIUS 服务器。但是, 在这种情况下, RADIUS 只支持点到点的安全性, 即中间的每一个代理 RADIUS 服务器都有能力对用户的认证、计费信息进行修改, 这也是一个很大的安全隐患。

DIAMETER 协议是 IETF 为了解决 RADIUS 的不足而设计的, 它在 RADIUS 的基础之上增加了新的功能, 更能满足网络接入和应用需求, 主要表现在以下几方面。

(1) 轻量级而且易于实现。DIAMETER 基本协议的目标是为各种应用扩展协议提供

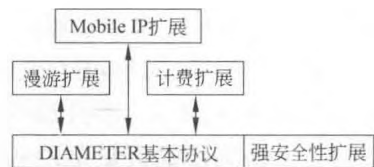


图 15-22 DIAMETER 的框架结构

安全、可靠、快速的传输平台，因此必须是轻量级的和易于实现的。

(2) 大的属性数据空间。在 DIAMETER 中，数据对象是封装在 AVP (Attribute Value Pair) 中的，AVP 用来传输用户的认证信息和授权信息、交换用以计费的资源使用信息、中继代理和重定向 DIAMETER 消息包等。随着网络的复杂化，DIAMETER 消息包所要携带的信息越来越多，因此属性空间一定要足够大才能满足未来大型复杂网络的需要。

(3) 支持同步的大量用户的请求。随着网络规模的扩大，AAA 服务器要求同时处理大量的用户的请求，这要求 NAS 端能保存大量等待认证结果的用户的接入信息，RADIUS 的 255 个同步请求显然是不够的，DIAMETER 中定义了同时支持 2^{32} 个用户的接入请求。

(4) 可靠的传输机制和错误恢复机制。DIAMETER 要求能够控制重传策略，这一点在 NAS 切换到一个备用 DIAMETER 服务器时更加重要。DIAMETER 还支持窗口机制，这要求每个会话方动态调整自己的接收窗口，以免发送超出对方处理能力的请求。

虽然 DIAMETER 和 RADIUS 有很大的不同，但是作为一个完善的认证协议，RADIUS 还是有很多值得 DIAMETER 借鉴的东西；作为一个还处于草案阶段的协议，DIAMETER 还有很多方面需要进行改进。

15.7.2 移动 IP 与 AAA 的结合

1. 移动 IP 下的 AAA 模型

具有移动 IP 的 AAA 服务器如图 15-23 所示。AAAF 和 AAAH 完成认证功能，FA 和 HA 完成授权和计费功能。当一个移动节点 MN 漫游到外地域时，需要在外地域中进行注册。在初始注册过程中，MN 需要访问 AAAH，AAAH 对移动节点的证书进行验证；认证成功后，FA 得到授权继续处理移动节点的注册过程。初始的 AAA 事务不需要 HA 的参与，但移动 IP 要求 HA 和 FA 处理随后的每一个注册过程，如图 15-23 中虚线所示。要使 HA 和 FA 能够处理以后的注册过程，这意味着在初始注册过程中，通信各实体之间要执行一系列的协议。在初始注册过程完成后，AAAF 和 AAAH 就不再参与交互，随后的注册过程只需沿着图 15-23 中的虚线路径进行即可。

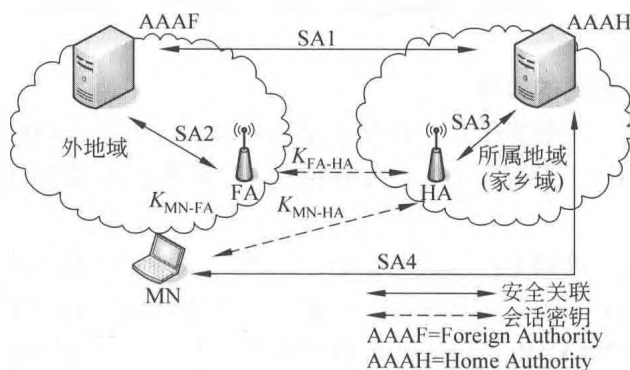


图 15-23 具有移动 IP 的 AAA 服务器

任何由 FA 通过 AAAF 送往 AAAH 的移动 IP 数据对 AAA 服务器来说都是不透明的。AAA 服务器所需要的授权数据都必须由 FA 传送给它们，这些授权数据由 MN 提供。FA 为一个在移动 IP 注册协议和 AAA 之间的转换代理。

对于不同域中的两个节点之间交换的数据, 需要采取一定的措施来保证它们的安全性, 这通过对称或非对称的密码算法来实现。

为了保证随后的注册过程的安全性, AAA 服务器必须在初始移动 IP 注册过程中进行密钥的分配。这些分配的密钥可以提供必要的安全功能。

2. AAA 下的移动 IP 注册

为了保证注册过程中交互的信令消息的安全, AAA 方案要求通信实体之间预先建立 4 个安全关联。这 4 个安全关联分别为:

- AAAF 与 AAAH 共享的安全关联 (SA1)。
- AAAF 与 FA 共享的安全关联 (SA2)。
- AAAH 与 HA 共享的安全关联 (SA3)。
- AAAH 与 MN 共享的安全关联 (SA4)。

在认证及注册之后, AAA 过程已经结束。MN、FA 和 HA 之间开始执行移动 IP 操作, AAAF 和 AAAH 不再参与。为了确保在认证之后 FA、HA、MN 之间传递的移动 IP 消息的安全性, AAAH 要在认证过程中为它们分发 3 个会话密钥 (Session Key), 以便它们在两两之间建立安全关联。这 3 个共享的会话密钥分别为:

- MN 与 HA 共享的密钥 (K_{MN-HA})。
- MN 与 FA 共享的密钥 (K_{MN-FA})。
- FA 与 HA 共享的密钥 (K_{FA-HA})。

移动 IP 的认证注册过程如图 15-24 所示, 具体步骤如下。

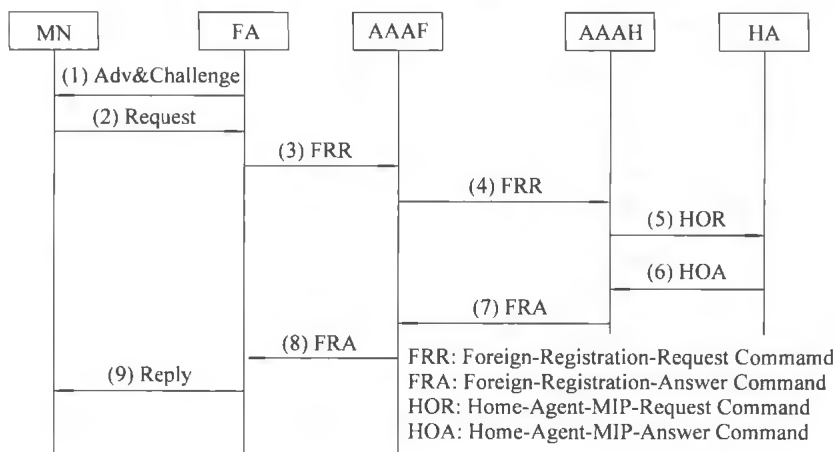


图 15-24 移动 IP 的认证注册过程

(1) MN 进入外地域, 开始监听 FA 的路由广播消息, 并根据消息中的地址前缀, 结合接口标识, 生成转交地址 COA。

(2) MN 将包含身份标识 NAI (user@realm)、注册请求及密码等认证数据的请求消息发送给 FA。

(3) FA 根据消息中的随机数或时间戳判断消息是否新鲜。如果新鲜, FA 将提取出 NAI、密码、所属地等信息, 重新封装成 AAA 请求消息 FRR, 并将 FRR 发送给 AAAF。

(4) AAAF 收到 FRR 消息后，首先利用与 FA 共享的安全关联 SA2 验证消息是否来自真正的 FA，如果验证成功，将该消息转发给 AAAH 服务器进行 MN 身份认证。

(5) AAAH 利用 SA1 验证收到的 FRR 消息是否来自合法的 AAAF。若验证成功，则根据 NAI 和用户认证数据验证用户身份是否合法。如果确为合法用户，AAAH 提取出注册请求消息并嵌入 HOR 消息中，发送给 HA 进行绑定更新，并根据要求分发 MN 的会话密钥。

(6) HA 对 MN 绑定更新成功后，生成注册应答消息，将其封装在 HOA 消息中，返回给 AAAH。

(7) AAAH 把注册应答和用户认证授权信息封装成 FRA 消息，转发给 AAAF。

(8) FRA 消息中包含认证结果。如果对 MN 的身份认证成功，则 AAAF 将 MN 相关信息（如会话密钥等）添加到缓存中；同时将 FRA 转发给 FA。

(9) FA 将嵌入在 FRA 消息中的注册应答消息发送给 MN。若认证是成功的，则 FA 将允许 MN 享受网络服务。

认证注册过程主要完成了以下任务：①认证 MN 的身份，并根据认证结果对 MN 授权；②保护注册消息的安全，并按注册请求消息中的内容更新 MN 绑定列表；③为 FA、HA、MN 之间分配会话密钥。

习 题

一、选择题

- 确定用户身份的技术称为_____。
A. 认证 B. 授权 C. 保密 D. 访问控制
- _____是最常用的认证机制。
A. 智能卡 B. PIN C. 生物特征识别 D. 口令
- _____是认证令牌随机性的基础。
A. 口令 B. 种子 C. 用户名 D. 杂凑函数
- 基于口令的认证是_____认证。
A. 单因子 B. 双因子 C. 三因子 D. 四因子
- 基于时间的令牌中的可变因子是_____。
A. 种子 B. 随机挑战值 C. 当前的时间 D. 计数器值
- 基于事件的令牌中的可变因子是_____。
A. 种子 B. 随机挑战值 C. 当前的时间 D. 计数器值
- 生物认证基于_____。
A. 人的特性 B. 口令 C. 智能卡 D. PIN
- 在_____认证中，只有一方认证另一方。
A. 单向 B. 双向 C. 基于时间戳的 D. 基于身份的

二、简答题

- 在实际应用中，人们对身份认证系统的要求有哪些？

2. 身份证明系统可以分为哪两类？它们之间有什么区别？
3. 什么是口令认证？请简述这种方式的优缺点。
4. 什么是一次性口令？实现一次性口令有哪几种方案？请简述它们的工作原理。
5. 如何解决基于时间机制令牌的失步问题？
6. 如何解决基于事件机制令牌的失步问题？
7. 动态口令令牌有哪两种类型？它们的工作原理有何不同？
8. 基于生物特征的身份识别有哪几种？与其他身份认证相比，它们有哪些优缺点？
9. 请画一个表格，详细比较各种一次性口令认证方案的优缺点。
10. 移动 IP 的安全问题集中在哪两个方面？移动 IP 与 AAA 结合主要解决的问题是什么？
11. 移动 IP 的网络架构是什么样的？
12. 简要描述移动 IP 与 AAA 结合的注册过程。